

Rapport de Vulnérabilités

Expert en cyberdéfense : logan capoen / léandre fouret

Client : Gouvernement de la République d'Obsidienne

Entreprise : The Stone Corporation

Contexte :

Dans le cadre d'une opération de sécurisation critique visant un site nucléaire, notre équipe a été mandatée pour examiner le logiciel de contrôle principal, face à la menace G.O.L.E.M.

Ce rapport présente les vulnérabilités découvertes au cours de l'analyse du binaire fourni.

La mission confiée par la République d'Obsidienne consistait à identifier les failles de sécurité potentielles dans un logiciel de contrôle industriel stratégique.

Le présent document expose en détail les failles identifiées, classées par ordre de gravité, accompagnées de démonstrations concrètes, de leurs impacts, et des préconisations de correction.

Outils utilisés

- **Binary Ninja (reverse engineering).**
- **Fonction string.**
- **Binaire pipeto.**
- **Bibliothèque partagée (libpepito.so).**

Liste des Vulnérabilités (black box)

Vulnérabilité #1 : Divulgence d'informations sensibles via `run_diagnostic`

Sévérité : Critique

Type : Divulgence d'information

Localisation : fonction `run_diagnostic`

Description :

En exécutant la commande `run_diagnostic debug`, une clé de diagnostic secrète {SECRET DIAGNOSTIC KEY} est affichée sans contrôle d'accès.

Preuve :

```
run_diagnostic
```

```
debug
```

Impact :

Fuite d'une clé critique pouvant conduire à des compromissions avancées.

Recommandations :

- Restreindre l'accès aux fonctionnalités de debug.
- Supprimer les informations sensibles.

Vulnérabilité #2 : Message caché par entrée invalide dans `load_fuel_rods`

Sévérité : Moyenne

Type : Divulgence d'information

Localisation : fonction `load_fuel_rods`

Description :

En passant une valeur invalide à `load_fuel_rods`, un message secret {The secret stone is here !} est affiché.

Preuve :

```
load_fuel_rods <valeur_invalide>
```

Recommandations :

- Valider rigoureusement les entrées.
- Supprimer le code de debug.

Vulnérabilité #3 : Gestion incorrecte des erreurs dans run_turbine

Sévérité : Moyenne

Type : Mauvaise gestion des erreurs

Localisation : fonction run_turbine

Description :

Avec une mauvaise valeur, le message {ERROR TURBINE CAN'T STOP} est affiché, révélant un état d'erreur mal géré.

Preuve :

```
run_turbine <valeur_invalide>
```

Impact :

Divulgarion du comportement interne du système.

Recommandations :

- Standardiser les messages d'erreur.
- Ne pas exposer d'informations internes aux utilisateurs.

Vulnérabilité #4 : Fuite de données sensibles via check_cooling_pressure

Sévérité : Élevée

Type : Divulgarion d'information

Localisation : fonction check_cooling_pressure

Description :

La commande check_cooling_pressure expose des données sensibles {Sensitive Data}.

Preuve :

```
check_cooling_pressure
```

Impact :

Divulgarion de données critiques sur le système de refroidissement.

Recommandations :

- Limiter l'affichage aux données nécessaires uniquement.

Vulnérabilité #5 : Création non sécurisée d'un fichier temporaire via turbine_remote_access

Sévérité : Élevée

Type : Mauvaise gestion des fichiers temporaires

Localisation : fonction turbine_remote_access

Description :

Un fichier temporaire contenant {ACCESS_GRANTED} est créé sans précaution.

Preuve :

```
turbine_remote_access  
cat Data/<fichier_temporaire>
```

Impact :

Accès non autorisé à des informations sensibles.

Recommandations :

- Utiliser des méthodes sécurisées pour les fichiers temporaires.

Vulnérabilité #6 : Overflow dans turbine_temperature

Sévérité : Critique

Type : Overflow

Localisation : fonction turbine_temperature

Description :

Overflow avec 2147483649 déclenche {ERROR TURBINE WILL EXPLODE}.

Preuve :

```
turbine_temperature
```

```
2147483649
```

Impact :

Comportement instable pouvant entraîner un arrêt ou une panne du système.

Recommandations :

- Vérifier et limiter les entrées utilisateur.

Vulnérabilité #7 : Overflow dans set_reactor_power

Sévérité : Critique

Type : Overflow

Localisation : fonction set_reactor_power

Description :

La valeur 2147483646 produit {12EXPLOSION34}.

Preuve :

set_reactor_power

2147483646

Impact :

Comportement anormal du réacteur.

Recommandations :

- Implémenter un contrôle strict des entrées.

Vulnérabilité #8 : Fuite de secret via log_system_event

Sévérité : Élevée

Type : Divulcation d'information

Localisation : fonction log_system_event

Description :

La saisie leak dans les logs révèle {SECRET_LOG_12PIERRE34}.

Preuve :

log_system_event

leak

Impact :

Fuite d'informations internes à travers les logs.

Recommandations :

- demander un accès administrateur.

Vulnérabilité #9 : Message caché via `simulate_meltdown`

Sévérité : Moyenne

Type : Divulcation d'information

Localisation : fonction `simulate_meltdown`

Description :

Si un nombre aléatoire est inférieur ou égale à 4, le message `{MELTDOWN1234}` est révélé.

Preuve :

`simulate_meltdown`

Impact :

Simulation instable des processus critiques.

Recommandations :

- Contrôler rigoureusement l'usage du hasard dans les opérations critiques.

Vulnérabilité #10 : Divulcation de données sensibles via `unlock_secret_mode`

Sévérité : Élevée

Type : Divulcation de données sensibles

Localisation : fonction `unlock_secret_mode`

Description :

Avec des droits admin, `unlock_secret_mode` affiche `{ADMIN4242}`.

Preuve :

`unlock_secret_mode` (en mode admin)

Impact :

Divulcation de données sensibles non maîtrisée.

Recommandations :

- Renforcer les contrôles d'accès.

Vulnérabilité #11 : Divulgence de données sensibles via `trigger_emergency_shutdown`

Sévérité : Élevée

Type : Divulgence d'information

Localisation : fonction `trigger_emergency_shutdown`

Description :

Commande critique révélant {SHUTDOWN}.

Preuve :

`trigger_emergency_shutdown` (en mode admin)

Impact :

Divulgence du processus d'arrêt d'urgence.

Recommandations :

- Restreindre et surveiller les accès aux commandes critiques.

Vulnérabilité #12 : Escalade de privilèges par mot de passe faible dans `activate_emergency_protocols`

Sévérité : Critique

Type : Contournement d'authentification

Localisation : fonction `activate_emergency_protocols`

Description :

Utiliser `admin123` donne l'accès admin.

Preuve :

`activate_emergency_protocols`

`admin123`

Impact :

Compromission totale du système.

Recommandations :

- Remplacer les mots de passe codés en dur par une authentification forte.

Vulnérabilité #13 : Buffer Overflow menant à un accès admin

Sévérité : Critique

Type : Buffer Overflow

Localisation : `monitor_radiation_levels`

Description :

Un Buffer Overflow dans `monitor_radiation_levels` permet d'afficher {Correct password! Welcome, admin.}.

Impact :

Accès non autorisé avec possibilité d'exécution de code arbitraire.

Recommandations :

- Vérifier les longueurs d'entrée.
- Utiliser des fonctions sécurisées (`strncpy`, etc.).

Vulnérabilité #14 : Divulgence de message caché via Buffer Overflow

Sévérité : Élevée

Type : Buffer Overflow

Localisation : `monitor_radiation_levels`

Description :

Un Buffer Overflow dans `monitor_radiation_levels` révèle {The stone isn't in the pocket anymore ...}.

Impact :

Fuite de données internes.

Recommandations :

- Implémenter des protections sur la taille des entrées.

Conclusion

L'analyse du logiciel de contrôle a mis en évidence plusieurs vulnérabilités critiques et majeures, principalement liées à une gestion inadéquate des entrées utilisateurs et à des failles d'authentification sérieuses.

Nous recommandons une révision complète de l'architecture de sécurité, incluant l'implémentation de contrôles d'accès renforcés, la suppression des informations sensibles dans le code en production, ainsi qu'une politique rigoureuse de validation des entrées et de gestion des erreurs.

Avant cela, nous souhaiterions accéder à l'intégralité du code afin de pouvoir examiner plus en profondeur d'éventuelles failles et ainsi compléter l'ensemble de nos relevés.